

INGT1002 Gruppeinnlevering IKT-sikkerhet

Gruppe 42: John-Ivar Eriksen

Case: StudyBuddy-app (case 1)

Oppgave 1 - Beskrivelse av CIA

CIA (*Confidentiality, Integrity and Availability*) er en grunnleggende modell for moderne informasjonssikkerhet. Den veileder utvikling og implementering av retningslinjer og kontroller som beskytter informasjon. Modellen gir en strukturert tilnærming til sikring av data og systemer ved å gå adressere sentrale sikkerhetsmål. Dette bidrar til å redusere risikoen for uautorisert tilgang, datainnbrudd og tjenesteforstyrrelser, samt sikre etterlevelse av lover og regler, samtidig som man opprettholder pålitelig og sikker drift.

Konfidensialitet handler om å beskytte sensitiv informasjon mot uautorisert tilgang, slik at den kun er tilgjengelig for de som skal ha tilgang til den. Tiltak som kryptering og tilgangskontroll er viktig for å opprettholde konfidensialitet.

Integritet er å sikre at dataene forblir nøyaktige og pålitelige, og ikke kan endres uten autorisasjon. For å ivareta integritet benyttes sjekksummer og digital signering for å bekrefte at dataene ikke er tuklet med eller på annen måte har blitt endret.

Tilgjengelighet betyr at informasjon og systemer er tilgjengelig for autoriserte brukere når de trenger det. Å legge opp til redundans i systemene, samt beskyttelse mot tjenestenektangrep (*Denial of Service, DoS*) og distribuerte tjenestenektangrep (*Distributed Denial of Service, DDoS*) er vanlige tiltak for å sikre tilgjengelighet.

Utfordringer for StudyBuddy tilknyttet CIA:

Konfidensialitet

Siden StudyBuddy behandler sensitiv informasjon er konfidensialitet veldig viktig. Appen må sikre dataene mot avlytting og manipulering under overføring mellom bruker og server ved bruk av HTTPS med TLS. For å beskytte meldinger og dokumenter ytterligere, bør appen bruke ende-til-ende-kryptering, (*E2EE, End-to-End Encryption*), slik at kun avsender og mottaker kan lese innholdet, selv om dataene går via StudyBuddys servere. Dette krever at dataene krypteres og dekrypteres på brukernes enheter, hvilket kan øke kompleksiteten i utviklingsprosessen og krever nøye implementering for å sikre korrekt funksjonalitet.

I tillegg til dataoverføring, må lagringstilstanden til informasjon på servere vurderes nøye. Data kan lagres enten kryptert, slik at selv de med administratortilgang til serveren ikke har tilgang til innholdet, eller ukryptert, altså i klartekst, som er vanlig i de fleste tjenester og apper. Kryptert lagring gir høyere personvern og sikkerhet, men legger også begrensninger på enkelte funksjoner for datahåndtering, i tillegg til at det krever mer av utviklerne for å implementeres på en god måte.

En annen viktig faktor for konfidensialitet er tilgangskontroll. Autoriserte ansatte eller utviklere har ofte tilgang på sensitive data, hvilket gjør dem populære og sårbare mål for sosial manipulering (*Social engineering*), der en angriper forsøker å manipulere den ansatte direkte og dermed få tilganger via tillitsmisbruk. For å unngå dette, må alle ansatte med autorisasjon og tilgang til sensitive opplysninger være bevisst sitt ansvar og de sikkerhetsprosessene som beskytter data. Bruk av tofaktorautentisering (*2FA*) er en enkel løsning og solid sikkerhetsbarriere for å begrense tilgang til kun legitime brukere.

Til slutt er det viktig å ha gode rutiner for å holde kontroll på brukertilganger og oppdatere dem regelmessig. Ansatte eller utviklere som får tilgang til sensitive opplysninger kan utilsiktet beholde denne tilgangen over tid, selv etter at det ikke lenger er nødvendig. Ved å ha gode retningslinjer og rutiner for tilgang og logging av brukertilgang, kan risikoen for interne angrep og utilsiktet eksponering av brukerdata reduseres betydelig.

Integritet

For å ivareta dataintegriteten må både appen og de bakenforliggende systemene lagre dataene på en måte som beskytter mot uautoriserte endringer. Dette krever innsikt i protokoller og teknologi for lagring og overføring av data. Ved bruk av ekstern lagringstjenester, må man likevel kunne vurdere om disse ivaretar dataene nødvendig grad av sikkerhet.

Tjenesten og appen må ha mekanismer for å oppdage endringer, både ønskede og uønskede. Ved å bruke signaturer og sjekksummer på dokumenter, meldinger og notater kan endringer spores og verifiseres. Dette kan derimot være krevende å implementere riktig.

Brukerprofilene må sikres mot tilgang og manipulasjon fra uvedkommende. Om utenforstående får tilgang til brukerprofiler grunnet dårlig sikkerhet vil tilliten brukere har til appen svekkes, og StudyBuddy kan få bøter for brudd på GDPR og lekkasje av personopplysninger. De bør brukes etablerte biblioteker og metoder for å sikre brukerprofiler og tilganger, og utviklerne må være nøye med å følge opp sikkerhetsoppdateringer i all kode og programvare som benyttes.

Tilgjengelighet

En utfordring for tilgjengelighet er tjenestenektangrep, som kan gjøre appen og tjenesten blir utilgjengelig for brukere. Tjenester som Cloudflare tilbyr beskyttelse mot slike angrep, men problemer kan også oppstå ved plutselig høy pågang fra vanlige brukere, hvis systemet ikke er dimensjonert for det.

Om tjenesten skulle feile og bli "tatt ned", enten av angrep, plutselig økning i brukere, eller systemfeil, må det legges til rette for redundans. Om tjenesten feiler, må det finnes backup av datene som alltid er oppdatert til siste versjon før tjenesten gikk ned, i tillegg til systemer som kan spinnes opp for å ta over for det som sluttet å fungere.

Skalerbarhet og ytelse går hånd i hånd med DoS-trusselen. Etterhvert som tjenesten vokser i popularitet, kan økt antall samtidige brukere føre til både ytelsesproblemer og at tjenesten kollapse under pågangen av brukertilkoblinger. Det er derfor viktig å velge teknologier, både programvare og maskinvare, med omhu, slik at nødvendige oppdraderinger i kapasitet kan gjøres så enkelt som mulig. Dette krever altså at det tenkes fremover i tid. Oppgraderinger av servere og nettverk krever både økonomiske og tekniske ressurser, i tillegg til teknisk kompetanse til å planlegge og legge til rette for dette.

Oppsummering

Bruk av CIA-prinsippene i StudyBuddy-appen gir et solid grunnlag for å kunne balansere sikkerhet og brukervennlighet, i tillegg til at utviklerne må vurdere de forskjellige utfordringene knyttet til hver komponent i CIA-triaden. Dette legger til rette for at de vanligste fallgruvne dekkes, for eksempel ved å legge opp til gode rutiner for autorisert tilgang, skalerbarhet på tjenesten og robuste løsninger for å sikre dataintegritet.

Oppgave 2 - Viktigheten av sikkerhetskultur

Med sikkerhetskultur menes de verdier, holdninger og atferd som finnes blant medlemmene i en organisasjon, når det gjelder å ivareta informasjonssikkerhet. En sterk sikkerhetskultur vil innebære at alle, fra toppen av ledelsen og ned til laveste mann på gulvet, er bevisst på sikkerhetsrisikoer og sin rolle i å bidra til å beskytte både data og systemer. Dette krever et kontinuerlig fokus på opplæring, klare og fornuftige retningslinjer og at sikkerhetstiltakene er en integrert del av arbeidsprosesser og daglig aktivitet. Selv om sikkerhetskultur ofte ses i sammenheng med bedrifter eller organisasjoner, har den også en viktig plass i samfunnet forøvrig, i det daglige liv. Hvordan man håndterer egne, og andres, data er vel så viktig å være bevisst på som hvordan det gjøres på arbeidsplassen. Å dele andres personlige informasjon uten tillatelse, eller lemfeldig håndtering av egne data, kan føre til identitetstyveri, uthengelse av andre, i tillegg til å gjøre det enklere for angripere å utøve sosial manipulering for å få tilgang til informasjon både i jobb og privat sammenheng.

For StudyBuddy vil det være viktig å ha en felles grunnforståelse for hvorfor sikkerhet er viktig. For å få alle ansatte med på dette er det viktig å koble det til noe annet enn bare økonomi. Hvis sikkerhet knyttes for mye opp mot økonomi, kan det gi et inntrykk av at ledelsen kun er opptatt av fortjeneste. Dette kan føre til manglende respekt blant ansatte for både sikkerhetsmålene og ledelsens holdninger. En god strategi kan være å fokusere på ansvaret som følger med å sitte på sensitive opplysninger om brukere, og ikke minst menneskelig gjøre brukerne. Behandle andres data med den respekten du vil at andre skal behandle dine med. Om de ansatte føler seg som en del av et fellesskap som alle ivaretar sikkerheten vil de fleste også føle et ansvar for å bidra til dette, i stedet for at det oppstår en følelse av at sikkerheten bare er et økonomisk spørsmål.

Utover en følelse av felles ansvar, kreves en solid grunnopplæring, slik at de ansatte faktisk har kompetansen til å ivareta sikkerhet. Utviklere bør få tilgang til regelmessig opplæring i sikkerhetspraksis, som hvordan skrive sikker kode, bruke kryptering og sikre tilgangskontroll. Kur og seminarer om det siste innen sikkerhetstrusler, informasjonssikring og sikker programmering er viktig for å holde utviklerne både oppdatert og engasjert. Det samme gjelder øvrige ansatte, men det er viktig å tilpasse opplæring til de forskjellige interesse- og stillingsnivåene, slik at alle får en risikoforståelse som er, og føles, relevant for deres arbeid. Å ha klart definerte roller og ansvarsområder for ansatte, hvilket ansvar de har og hvilke retningslinjer som gjelder spesielt for dem, gjør det enklere for den enkelte å følge opp sin del av sikkerhetsansvaret.

Brukeren er også en del av sikkerhetskulturen. Derfor må StudyBuddy oppfordre til bruk av sterke passord, bevisstgjøre dem om enkle tiltak for å unngå uautorisert tilgang, som å aktivere avtofaktoraутентisering.

Det å ha gode retningslinjer som beskriver enkelt og tydelig hvordan informasjon skal behandles og beskyttes er en grunnleggende del av god sikkerhetskultur. Dette gjør det lettere for ansatte å vite hva de har å forholde seg til, og vil fungere som en rettesnor og veiledning i arbeidshverdagen. Disse bør dekke alt, fra bruk av sikre utviklingsmetoder og kodegjennomgang, til hvordan tilgang til sensitive data skal håndteres. Det er særskilt viktig at slike retningslinjer oppdateres i takt med ny teknologi og nye trusler. Tydelige sikkerhetsretningslinjer gir ansatte en klar veiledning for hvordan informasjon skal behandles og beskyttes. Gjennom designprinsipper som "*Secure by design*" kan StudyBuddy legge til rette for at sikkerhet blir en integrert del av hele utviklingsprosessen, noe som skaper en solid grunnmur for sikkerhetskulturen. Å legge inn tid til gode sikkerhetsanalyser ("*audits*") og testing gjennom hele utviklingsprosessen og før lansering vil øke sannsynligheten for at produktet ikke har alvorlige feil, samtidig som både utviklere, ansatte og bevisste brukere får økt tillit til produktet. Deretter må det investeres i kontinuerlig overvåkning og forbedring av appen, for å adressere sårbarheter og problemer som dukker opp over tid. Kvalitetstesting blir ofte nedprioritert, til fordel for rask utrulling av produktet, men det viser seg som regel å være en kortsiktig og dårlig løsning.

Til slutt er det viktig for god sikkerhetskultur at håndtering av trusler og repons på sikkerhetshendelser er noe både utviklere, ansatte og ledelsen er forberedt på. Det bør være gode og kvalitetssikrede beredskapsplaner og prosesser, for å sikre rask og effektiv respons på sikkerhetshendelser, i tillegg til retningslinjer for god kommunikasjon med brukerne i slike tilfeller. Ved å kommunisere åpent og tydelig, og demonstrere en ansvarlig holding til sikkerhet, er det større sannsynlighet for at StudyBuddy vil kunne opprettholde tilliten hos brukerne, til tross for sikkerhetsbrudd.

Oppgave 3 - Identifisering av uønskede hendelser

Tre potensielle uønskede hendelser som er svært relevante for appen, og en tjeneste som StudyBuddy, er:

1. Eksponering av brukernes personopplysninger.
2. Uautorisert tilgang til chat, kalender og delte dokumenter.
3. Tjenestenektangrep (DoS/DDoS).

1. Eksponering av brukernes personopplysninger

Eksponering av sensitive persondata, både i form av chatlogger, dokumenter og den øvrige brukerprofilen er noe enhver tjeneste som håndterer personopplysninger er utsatt for. StudyBuddy er intet unntak, og beskyttelse mot slik eksponering, lekkasjer og brudd er avgjørende for å opprettholde brukernes tillit. For eksempel kan push-varsler inneholde sensitiv informasjon; dersom disse vises på en låseskjerm, kan potensielle angripere tilegne seg nyttig informasjon uten autorisasjon. Et slikt brudd kan skade appens omdømme og føre til juridiske konsekvenser grunnet brudd på personvernsløvgivning som GDPR. Dette kan også medføre økonomiske tap i form av brukerflukt og bøter fra myndighetene.

2. Uautorisert tilgang til chat, kalender og delte dokumenter

Uautorisert tilgang til gruppechatter, kalender og delte dokumenter kan resultere i at uvedkommende får direkte tilgang til innholdet på plattformen. Dette kan følge på både personlig og karrieremessig plan. Gruppechattene og dokumentene kan inneholde både faglige diskusjoner og personlige meninger og uttrykk, som ikke er ment for offentligheten. Dokumenter med oppgaver, referansemateriale, datasett og oppgaver kan være av sensitiv karakter, for eksempel i forbindelse med forskning som inneholder taushetsbelagt informasjon. Hvis uvedkommende får tilgang til slikt materiale, kan det føre til spredning av sensitiv informasjon, brudd på akademisk integritet, brudd på taushetsplikt og misbruk av innhold. I tillegg kan uautorisert tilgang muliggjøre manipulering av data, hvilket gjør at dataintegriteten ikke lenger er ivaretatt. Siden appens kjernefunksjon er deling og kommunikasjon, må dette gjennomføres på en sikker måte.

3. Tenestenektangrep (DoS/DDoS)

Tjenestenektangrep er et vanlig problem, både i form av rettede angrep og på grunn av utilstrekkelig infrastruktur til å takle plutselig pågang av vanlige brukere. Hvis tjenesten får nedetid, vil dette påvirke studentene som er avhengige av oppetid for å kommunisere og gjennomføre studiearbeidet. Uforutsett nedetid kan hindrestudentene i å jobbe med oppgaver og samarbeide på prosjekter, noe som raskt kan få negative konsekvenser for akademisk prestasjon, og ikke minst føre til unødvendig frustrasjon og stress. Tilgjengelighet er en del av CIA-triaden, og er kritisk både for brukeropplevelse og nytten av tjenesten. Hyppig eller langvarig nedetid kan føre til at brukere forlater plattformen til fordel for mer pålitelige alternativer.

Oppsummering

Disse hendelsene påvirker appens evne til å sikre konfidensialitet, integritet og tilgjengelighet. Databrudd og uautorisert tilgang truer konfidensialiteten og integriteten til brukerdata, mens DoS-angrep påvirker tilgjengeligheten. En usikker og utilgjengelig tjeneste mister raskt sin verdi for brukerne.

Oppgave 4 - Identifisering av trusler og sårbarheter

Trusler og sårbarheter som er relevante for de tre identifiserte hendelsene:

1. Eksponering av brukernes personopplysninger

Trusler

- **Kyberangrep (hacking):** Uvedkommende kan forsøke å bryte seg inn i systemet for å få tilgang til data.
- **Ondsinnet programvare (malware):** En angriper kan infiltrere systemet via malware for å samle inn data eller få uautorisert tilgang.
- **Insider-trusler:** Ansatte med tilgang til sensitive data kan lekke informasjon, enten med vilje eller utilsiktet.
- **Phishing-angrep:** En angriper lurer brukere eller ansatte til å gi fra seg innloggingsinformasjon gjennom falske e-poster og nettsider.

Sårbarheter

- **Svake mekanismer for autentisering:** F.eks svak passordpolicy og manglende tofaktoraутentisering kan gjøre det lettere for en angriper å få tilgang. I tillegg kan dårlig implementeringen av påloggingsautentisering øke risikoen.
- **Manglende kryptering:** Hvis data ikke er kryptert under lagring (*data at rest*), og under overføring (*data in transit*), er de mer utsatt for avlytting og tyveri. Det er viktig å unngå egenutviklede krypteringsløsninger, og heller bruke etablerte standarder.
- **Sikkerhetshull i programvare:** Kode og programvare brukt i appen og øvrige systemer kan inneholde uoppdagede eller urettede sikkerhetshull som kan utnyttes av en angriper for å få tilgang.
- **Utdaterte systemer:** Manglende oppdatering av servere, programvare og sikkerhetsprotokoller kan gjøre kjente sårbarheter tilgjengelig for utnyttelse av en angriper.

Påvirkning

Som diskutert tidligere kan tap av konfidensialitet gjøre at brukernes personopplysninger og private samtaler blir offentliggjort eller misbrukt. Dette kan føre til både juridiske sanksjoner, betydelige bøter, brukerflukt og store kostnader.

2. Uautorisert tilgang til chat, kalender og delte dokumenter

Trusler

- **Uautorisert inntrenger:** En angriper kan forsøke å få tilgang til en brukers private samtaler og dokumenter.
- **Man-in-the-Middle-angrep (MitM):** Avlytting eller manipulasjon av kommunikasjon mellom bruker og server, hvis den ikke er tilstrekkelig sikret.
- **Sosial manipulering (*social engineering*):** Angriperen kan manipulere brukeren eller ansette, direkte eller indirekte via bekjente eller andre tjenester de bruker, for å avsløre informasjon som kan gi tilgang til innlogging.
- **Bruk av tidligere lekket innlogging:** Hvis en bruker har innloggingsdetaljer som har blitt eksponert gjennom andre tjenester, kan en angriper bruke dette til å få tilgang og utestenge den legitime brukeren. Gjenbruk av passord er et vanlig sikkerhetsproblem.

Sårbarheter

- **Manglende ende-til-ende-kryptering (E2EE):** Uten E2EE kan meldinger og dokumenter være sårbare for avlytting og tilgang. De kan leses av i avlytting MitM-angrep, eller leses ved feilaktig tilgang til tjenestens server.
- **Utilstrekkelig tilgangskontroll:** Feilkonfigurerte eller dårlig kontroll på brukerrettigheter kan gi brukere eller ansatte tilgang til data de ikke skal ha.
- **Svake sikkerhetsprotokoller:** Bruk av usikere eller utdaterte protokoller kan eksponere data under overføring eller lagring.
- **Manglende opplæring:** Brukere og ansatte som ikke er klar over sikkerhetsrisiko og "best practice" øker sjansen for at feil skjer.

Påvirkning

Brudd på konfidensialitet kan eksponere private samtaler, opplysninger og dokumenter, som kan bli misbrukt. Brudd på integritet kan føre til tap eller manipulasjon av data. I sum kan dette medføre risiko for blant annet persondata på avveie, identitetstyveri, tap av viktig data og brudd på taushetsplikt. Dette kan igjen føre til juridiske konsekvenser og tapt tillit fra brukere.

3. Tenestenektangrep (DoS/DDoS)

Trusler

- **Distribuerte tjenestenektangrep:** Ved bruk av infiserte nettverk (botnett) kan angripere overvelde tjenestens servere med søppeltrafikk.
- **Målrettede angrep:** Økonomisk eller ideologisk motiverte angrep, utført av konkurrenter eller aktivistgrupper, for å skade tjenesten. Eller angrep som utfører "for the lols".
- **Utnyttelse av sårbarheter:** Sårbarheter i nettverksprotokoller eller utdatert programvare.
- **Overbelastning grunnet dårlig skalering:** Plutselig økning i trafikk fra legitime brukere kan få systemet til å knele på lik linje med et målrettet DDoS-angrep.

Sårbarheter

- **Utilstrekkelig infrastruktur:** Uten tilstrekkelig skalerbarhet og redundans kan både legitim og illegitim trafikk føre til nedetid.
- **Dårlig nettverkskonfigurerings:** Feil eller mangler i nettverkskonfigurasjon kan gjøre det enklere for en angriper å utnytte sårbarheter.
- **Manglende overvåkning og responsplan:** Angrep, unormal eller høy aktivitet blir vanskeligere å oppdage i tide uten overvåkning, og dårlig eller manglende responsplan forsinker tiltak for å stoppe eller begrense omfanget av en hendelse.

Påvirkning

Nedetid og utilgjengelighet forstyrrer brukernes arbeid, og kan føre til brukerflut om det skjer ofte eller langvarig. Dette fører til økonomiske tap og skade på omdømme.

Oppgave 5 - Overordnet risikoanalyse

Risikotabell

Hendelse	Sikkerhetsmål (CIA)	Sannsynlighet for at inntreffer	Konsekvens av hendelse	Risiko (sannsynlighet * konsekvens)	Vurdering
1. Eksponering av personopplysninger	Konfidensialitet	Middels	Alvorlig	Høy	Uakseptabel
- Malware		Middels	Alvorlig	Høy	Høy
- Hacking		Middels	Alvorlig	Høy	Høy
- Insider		Lav	Alvorlig	Middels	Må reduseres
- Phising		Middels	Alvorlig	Høy	Høy
2. Uautorisert tilgang til chat, kalender, dokumenter, osv.	Konfidensialitet Integritet	Middels	Betydelig	Middels til høy	Må reduseres
- MitM		Middels	Betydelig	Lav	
- Social engineering		Lav	Betydelig	Middels	
- Stjålet innloggingsinfo		Høy	Betydelig	Høy	
3. Tjenestenektangrep (DoS)	Tilgjengelighet	Middels	Moderat	Moderat til middels	Bør håndteres
- DoS, DDoS		Høy	Moderat	Middels	
- Sårbarheter i programvare		Middels	Moderat	Middels	
- Dårlig skalerbarhet		Middels	Moderat	Middels	

Figur 1, risikotabell/matrise.

Forklaring av vurderingen

1. Eksponering av personopplysninger:

- **Sannsynlighet:** Middels, grunnet "vanlige" trusler, som hacking og phishing.
- **Konsekvens:** Alvorlig, grunnet de juridiske konsekvensene, skade på omdømme, og potensielle følger for berørte brukere.
- **Risiko:** Høy, altså uakseptabel. Dette krever at utviklerne må ha solide og anerkjente tiltak mot dette som en del av grunnmuren i utviklingen av tjenesten/appen.

2. Uautorisert tilgang til chat, kalender og dokumenter

- **Sannsynlighet:** Middels, da trusler som MitM og stjålet innloggingsinfo er reelle og enkle å forsøke.
- **Konsekvens:** Betydelig, siden det påvirker brukerne både personlig og i skolesammenheng.
- **Risiko:** Middels til høy, og må dermed reduseres gjennom gode sikkerhetstiltak.

3. Tjenestenektangrep (DoS/DDoS)

- **Sannsynlighet:** Middels, siden DoS-angrep er relativt vanlige og billige å gjennomføre.
- **Konsekvens:** Moderat, siden det påvirker tilgjengelighet og brukertilfredshet,
- **Risiko:** Middels, og bør håndteres.

Oppgave 6 - Tiltak for å øke sikkerheten

Basert på risikoanalysen og de potensielle uønskede hendelsene som ble identifisert, anbefales følgende tiltak for å øke sikkerheten og redusere risikoen:

1. Eksponering av personopplysninger:

1. Ende-til-ende-kryptering: For å sikre at kun avsender og mottaker kan lese innholdet i meldinger og dokumenter. Integrering av E2EE i chat- og dokumentfunksjonene, ved bruk av anerkjente og etablerte krypteringsbiblioteker og -algoritmer som gjør det mulig for brukerne å kommunisere sikkert uten at dataene kan dekrypteres av serveren. Sikre korrekt og sikker generering og lagring av krypteringsnøkler på brukernes enheter. Utføre regelmessig sikkerhetsgjennomganger for å identifisere og tette eventuelle sårbarheter i krypteringen og implementeringen.
2. Kryptering av data både overføring og i hvile (*encrypted at rest*): Det må benyttes gode standarder for kryptering, som HTTPS med TLS for all overføring mellom klient og server, i tillegg til at data som lagres må krypteres med anerkjente algoritmer som er egnet til formålet, f.eks AES-256 som brukes av blant andre Google.
3. Tilgangskontroll og autentisering: Implementering av tofaktoraутentisering og bruk av rollebasert tilgangskontroll (*Role-based access control, RBAC*), i tillegg til gode rutiner for regelmessig revisjon av tilganger og rettigheter, vil bidra til å sikre at kun de som faktisk skal ha tilgang til sensitive data har det.
4. Sikkerhetsrevisjoner (*audits*) og penetrasjonstester (*pentest*): Ved å gjennomføre regelmessige *audits* av app og øvrige systemer, utført av aktører som spesialisere seg på dette, vil det være lettere å oppdage potensielle sikkerhetshull i tjenesten, i tillegg til at dette gir et inntrykk utad av at StudyBuddy tar sikkerheten på alvor, hvilket ikke bare gir et godt inntrykk hos potensielle brukere, men kan i seg selv være med på å redusere sannsynligheten for et angrep, ved å gi tydelige signaler om at sikkerheten er høyt prioritert.

2. Uautorisert tilgang til chat, kalender og dokumenter

1. Bruk av sikre og anerkjente API-er: Sikker og solid kommunikasjon mellom frontend og backend må gjøres ved bruk av kjente og vedlikeholdte API-er og metoder, f.eks JWT (JSON Web Tokens). API-endepunkter må sikret i henhold til kjente og etablerte standarder, og alle API-kall må autentiseres og valideres før applikasjonen gir brukere tilgang til konto eller innhold. Passord må håndteres etter alle kunstens regler, ved bruk av solide metoder for hashing, salting og sikker lagring. Bruk av sertifikater og kryptert overføring vil redusere sjansen for blant annet Man-in-the-Middle-angrep.
2. *Secure By Design* og *Secure Development Lifecycle* (SDL): Sikkerhet må være en grunnstein og integrert del av hele utviklingsprosessen. Følge SDL-prinsippene, og inkludert sikkerhetsanalyser i designfasen, kodegjennomgang (*code review*) og sikkerhetstesting. Bruk av både statiske og dynamiske analyseverktøy for å teste og avdekke sårbarheter i koden er også nyttig, men ikke en erstatning for profesjonelt utførte *audits*. Ikke minst må det sørges for at utviklere får opplæring i sikker programmering, og at de er oppdatert på det siste og nyeste innen sikkerhet.
3. Overvåkning og Intrusion Detection Systems (IDS): Ved å integrere IDS-løsninger og overvåkningsverktøy i systemet, er det lettere å oppdage unormal aktivitet og respondere raskere på både innbrudd, forsøk på innbrudd og "mistenkelig" aktivitet. Dermed kan hendeles avverges på et tidlig stadium, i tillegg til at man får en oversikt over hvor tjenesten trenger å forbedres.
4. Opplæring og bevisstgjøring: Ved å være proaktiv i opplæring av både ansatte og brukere, legger StudyBuddy opp til en god sikkerhetskultur, hvilket vil bidra stort til å redusere sjansen for at det oppstår hendelser som følge av den menneskelige komponenten. Brukere og ansatte må oppfordres til å bruke gode passord og 2FA, samt bli informert om de forskjellige risikoene og hvordan redusere dem. I tillegg kan det gjennomføres simulerte angrep via phishing og sosial manipulering på ansatte for å øke bevisstheten og for å få demonstrert hvordan det foregår og hvor lett det egentlig er å trække feil.

3. Tjenestenektangrep (DoS/DDoS)

1. (D)DoS-beskyttelse: Bruk av tjenester som Cloudflare, AWS Shield eller Akamai for å filtrere og mitigere DDoS-angrep. Mistenkelige forespørsler kan blokkeres eller utsettes ved hjelp av "*Web application firewall*" (WAF), og det kan implementeres *rate limiting* for å begrense antall forespørsler og tilkoblinger fra enkeltkilder.
2. Skalerbar infrastruktur: For å unngå at appen ikke blir tatt ned av vanlige brukere, må det sørges for at den takler plutselig økning i trafikk. Dette kan gjøres ved å bruke tjenester som AWS Auto Scaling, Google Cloud Autoscaler eller Azure Autoscaler. Slike tjenester er satt opp til å automatisk justere tilgjengelig kapasitet basert på trafikkmengden. Alternativer er lastbalansering (*load balancing*), altså å fordele trafikken jevnt over flere servere for å oppnå samme resultat. I tillegg kan containere (Docker) og container-håndtering (Kubernetes) brukes til å automatisk skalering.

3. Redundans og failover: For å sørge for at systemet forblir operativt selv ved systemfeil eller angrep, må det implementeres redundant infrastruktur med automatisk failover. Det vil si at systemet må finnes på, og kunne byttes over til, alternative servere, gjerne på andre lokasjoner enn hovedserveren. Hvis reservesystemet står på samme lokasjon som hovedsystemet, er det stort sannsynlighet for at et angrep på hovedsystemet også vil ødelegge for reserven. Redundante backup-systemer må også være satt opp, med hyppig og regelmessig sikkerhetskopiering, for å sørge for at systemet kan gjenopprettest rask ved nedetid.
4. Overvåkning og responsplan: Ved å sette opp overvåkning av systemet som ser på blant annet trafikk mønstre og ytelse i sanntid vil det være større sjanse for å oppdage et angrep i en tidlig fase. Det må også være gode rutiner og etablerte responsplaner for hvordan forskjellige typer angrep, inkludert DDoS-angrep, skal håndteres.

Oppgave 7 - Arbeidsfordeling

Arbeidsfordelingen har vært veldig rettferdig, og kunne vanskelig gjøres feil, i og med at gruppen består av én person.

Kunstig intelligens (ChatGPT) ble brukt til følgende:

- Sjekke for skrivefeil og grammatikkforbedringer.
- Forslag til endringer i ordlyd for bedre flyt.
- Diskutere argumenter i et forsøk på å få inn andre synsvinkler.
- Sjekke etter "faktuelle feil i min argumentasjon og beskrivelse av teknologi".

Spesielt har KI har blitt benyttet i oppgave 3, 4, 5 og 6 for å gå gjennom identifiseringen og beskrivelsen av hendelser, trusler, sårbarheter, risikoanalyse og tiltak, med instruks om å lese gjennom dem, og så kommentere på hvorvidt de er korrekt eller ikke, i tillegg til å gi en begrunnelse for hvorfor.

Ingen deler av besvarelsen er direkte generert eller "klipp og lim" fra LLM.

Antall ord utenom kildehenvisninger: 3999

Kildehenvisning

Lake, J. (2023, 1. november). *Confidentiality, integrity and availability (CIA triad)*. Comparitech. Hentet fra <https://www.comparitech.com/blog/information-security/confidentiality-integrity-availability/>

Washington University in St. Louis. (u.å.). *Confidentiality, Integrity, and Availability (The CIA Triad)*. Hentet fra <https://informationsecurity.wustl.edu/items/confidentiality-integrity-and-availability-the-cia-triad/>

Information security. (u.å.). I Wikipedia. Hentet 12. november 2024 fra https://en.wikipedia.org/wiki/Information_security

Kianpour, M. (2024). *Uke 42 - Introduksjon og sikkerhetskultur* [Forelesningsnotater]. INGT1002 Programmering, numerikk og sikkerhet. Institutt for datateknologi og informatikk (IDI), Norges teknisk-naturvitenskapelige universitet (NTNU).

Kianpour, M. (2024). *Uke 43 - Personvern, sårbarheter og trusler* [Forelesningsnotater]. INGT1002 Programmering, numerikk og sikkerhet. Institutt for datateknologi og informatikk (IDI), Norges teknisk-naturvitenskapelige universitet (NTNU).

Norsk senter for informasjonssikring (NorSIS). (u.å.-a). *Hva er sikkerhetskultur?* Hentet 13. november 2024 fra <https://norsis.no/fakta-og-veiledning/er-hva-er-sikkerhetskultur/>

Norsk senter for informasjonssikring (NorSIS). (u.å.-b). *Sosial manipulering*. Hentet 13. november 2024 fra <https://norsis.no/fakta-og-veiledninger/sosial-manipulering-2/>

Kianpour, M. (2024). *Uke 44 - Cyber risikovurdering* [Forelesningsnotater]. INGT1002 Programmering, numerikk og sikkerhet. Institutt for datateknologi og informatikk (IDI), Norges teknisk-naturvitenskapelige universitet (NTNU).

FastSlang. (u.å.). *For the lols*. Hentet fra <https://www.fastslang.com/for-the-lols>

Cloudflare. (u.å.). *What is a Web Application Firewall (WAF)?* Hentet fra <https://www.cloudflare.com/learning/ddos/glossary/web-application-firewall-waf/>

Google Cloud. (u.å.). *Data encryption at rest*. Hentet fra <https://cloud.google.com/docs/security/encryption/default-encryption>

Microsoft. (u.å.). *Security Development Lifecycle Practices*. Hentet fra <https://www.microsoft.com/en-us/securityengineering/sdl/practices>

Failover. (u.å.). I *Wikipedia*. Hentet 15. november 2024 fra <https://en.wikipedia.org/wiki/Failover>

Intrusion detection system. (u.å.). I *Wikipedia*. Hentet 15. november 2024 fra https://en.wikipedia.org/wiki/Intrusion_detection_system

Kubernetes. (u.å.). I *Wikipedia*. Hentet 15. november 2024 fra <https://en.wikipedia.org/wiki/Kubernetes>

Role-based access control. (u.å.). I *Wikipedia*. Hentet 15. november 2024 fra https://en.wikipedia.org/wiki/Role-based_access_control

Kianpour, M. (2024). *Uke 45 - Sikkerhetsmekanismer, lovverk og standarder* [Forelesningsnotater]. INGT1002 Programmering, numerikk og sikkerhet. Institutt for datateknologi og informatikk (IDI), Norges teknisk-naturvitenskapelige universitet (NTNU).

Kildekompasset. (u.å.). *APA 7th*. Hentet fra <https://kildekompasset.no/referansestiler/apa-7th/>